Claude handoff — Phase 4

waapi — Claude handoff report (Phase 4 closed-beta)

Date: 22 Oct 2026
Branch tip: `phase-4` @ `653b861`
Do not: merge to `main` yet · never `--admin` · never print secrets
Tag already cut: `phase-3-final` (Phases 1–3 on `main`)

Use this doc + the two PDFs + (optional) gitignored review packs for deep source dumps.

---

1. What this product is

waapi — unofficial multi-tenant WhatsApp HTTP API (Baileys) + React dashboard + static marketing site.
Not affiliated with WhatsApp/Meta; ban risk disclosed. Brand via `BRAND_NAME`.

Package	Role
`apps/api`	Fastify `/api/v1` + internal admin `:3001`
`apps/worker`	Sessions, QR, send jobs, `WA_DRIVER=baileys|fake`
`apps/dashboard`	Vite SPA (sessions, messages, settings, billing)
`apps/site`	Prerendered static HTML (Cloudflare Pages)
`packages/db`	Drizzle schema + migrations `0000`–`0010`
`packages/shared`	Zod schemas, plans, brand, error codes

Stack: pnpm monorepo, Postgres 16, Redis 7, BullMQ, Stripe/Paddle billing interface (manual default).

---

2. Progress vs closed-beta plan

Tier-1 closed-beta software: ~90–92%
Full master plan including Tier-2 stretch: ~78–82%

WP	Name	Tier	Status	Notes
—	Merge PR #3 + tag `phase-3-final`	—	Done	Safe; nothing deployed
A	Fake WhatsApp driver + Playwright	1	**Merged**	`WA_DRIVER=fake`, contract tests
B	Closed beta gate (invites)	1	**Merged**	`SIGNUPS_MODE`, mig `0008`
C	Email UX	1	**Merged**	`PUBLIC_APP_URL`, HTML/text templates
D	Account lifecycle	1	**Merged**	password, resend verify, delete
E	Session UX	1	**Merged**	disconnect/logout/delete/rename
F	Billing core	1	**Merged**	trial, plans, Paddle sandbox, mig `0009`
G	Admin CLI	1	**Merged**	`pnpm admin`, audit-logged
J	Public site + legal + terms	1	**Merged**	`apps/site`, mig `0010`
L	Go-live prep	1	**Merged**	preflight, backups, nginx Origin CA
M	Security pass	1	**Merged**	CI `39750120670` → `phase-4`
N	Reliability / abuse safeguards	1	**Not started**	disconnect emails, send limits, sweeper
H	Media + groups	2	**Not started**	stretch
I	Webhook event parity	2	**Not started**	stretch
—	Final PR `phase-4` → `main`	—	**Blocked** until N (+ optional H/I)	One PR then stop

---

3. Phase 4 process rules (still in force)

1. Branch `wp-<n>-<name>` from `phase-4`.
2. Test-first: failing `test:` commit → implement → lint/typecheck/tests → push → CI green.
3. Merge WP → `phase-4` yourself when both CI jobs green + DoD.
4. **Never** merge to `main`, never tag after `phase-3-final`, never `--admin`.
5. DoD: additive numbered migrations; tenant isolation on new routes; route-matrix no 5xx; no secrets/tokens/message bodies in logs/DB; runbook updated.

6. `packages/db` / API schema WPs one-at-a-time; UI/docs/ops may parallel.

---

4. Folder structure (high level)

```
waapi/
├── apps/api|worker|dashboard|site
├── packages/db|shared
├── deploy/nginx.conf, logrotate.waapi.conf
├── docs/runbook.md, design/billing.md, reports/*
├── scripts/admin-cli, preflight, backup/restore, smoke, probes
├── docker-compose*.yml
└── .github/workflows/ci.yml   # build + gitleaks
```

Migrations: `0000`…`0007` core → `0008` invites → `0009` billing → `0010` terms.

---

5. What WP-M delivered (latest merge)

Step	Result	Evidence
Log redact	Done	`apps/api/src/lib/log-redact.ts` — authorization, cookie, CSRF, token, password, text
nginx hardening	Done	HSTS, CSP (+ Turnstile), nosniff, referrer, frame-ancestors; block `/internal` `/metrics`; `client_max_body_size`; HTTP→HTTPS
Backups	Done	`age` public-key + sha256 + rclone (not AES-CBC); private key off-server
Prod guards	Done	Boot + preflight refuse: `WA_DRIVER=fake`, `TURNSTILE_DISABLED`, `SMOKE_MODE`, `EMAIL_DRIVER=console`, `DEV_RETURN_TOKENS`, `ALLOW_HTTP_WEBHOOKS`, placeholders
Smoke stack	Changed	`docker-compose.smoke.yml` uses **`NODE_ENV=test`** (prod boot no longer allows SMOKE_MODE)
Site legal guard	Done	Fail if prod/MOR + placeholder LEGAL_* / CONTACT / plan prices
Security triage	Done	`docs/reports/security-pass.md`
Cursor rules	OK	`waapi/.cursor/rules` = only `project.mdc` (gmb/deadletter are parent Cursor workspace, not this repo)
Paddle stale ts	Done	±5 min skew reject in `paddle-provider.ts`

CI: https://github.com/SyedIsmail-47/waapi/actions/runs/39750120670

---

6. Review packs (deep source for Claude)

Gitignored — regenerate with `node scripts/build-review-packs.mjs`:

File	~Size	Contents
`review-pack-1.md`	~84 KiB	Auth, cookies/CSRF, invites, admin, preflight, backup, nginx, compose, CI, `.env.example` + **Q1–Q6 answers**
`review-pack-2.md`	~62 KiB	Billing provider/Paddle/state machine, sessions/send, plans, schema, worker types

Q1–Q6 (summary — full evidence in pack-1 header)

1. **Invite atomic?** Yes — conditional `UPDATE … used_at IS NULL` inside register txn (`invites.ts`).
2. **Paddle raw + stale ts + account bind?** HMAC over `ts:rawBody`; stale ±5m rejected; checkout `accountId` from JWT → `custom_data` (route still JSON.stringifies parsed body — not byte-raw buffer).
3. **Trial expiry?** 402 `BILLING_EXPIRED`; grace then disconnect extras via queue; **keys not auto-revoked** by expiry alone.
4. **messages.upsert text?** Yes when present (`worker/.../manager.ts`); logs redact text; webhook payload purge via retention.

5. **Disconnect emails?** Not yet (WP-N). **Phone unique?** Yes — `sessions_phone_active_uidx`.
6. **Paddle events:** handled `transaction.completed` / `subscription.activated` / `payment_failed|subscription.past_due` / `subscription.canceled`; others ignored after idempotent ledger insert.

---

7. Remaining work (ordered)

WP-N (Tier 1 — next)
- Disconnect / logged_out / connection_replaced emails (dedupe 6h, opt-out, HTML+text, fake driver + mock mail)
- Per-plan send limits (min/day + 7-day warm-up) → 429 `SESSION_SEND_LIMIT` + Retry-After; dashboard usage
- Confirm/show phone partial unique; 409 `PHONE_IN_USE` + friendly UI
- Billing sweeper job (trial/past_due → expired, disconnect after grace) + tests

WP-H / WP-I (Tier 2 stretch)
- Media/groups design + send-media SSRF-safe; MediaStore TTL; inbound metadata only
- Webhook parity: messages.update, receipts, reactions, groups.update, event filters, schemas

Final
- Update `docs/reports` PDFs
- lint + typecheck + full tests + Playwright
- **One** PR `phase-4` → `main` with WP table + test counts + CI id — then **STOP**

---

8. How to run locally

```bash
cp .env.example .env   # 32-byte keys
pnpm install && pnpm docker:up && pnpm db:migrate && pnpm seed
pnpm dev:api && pnpm dev:worker && pnpm dev:dashboard
pnpm build:site
NODE_ENV=production pnpm preflight   # go-live check
```

Smoke: compose overlay with `NODE_ENV=test` + Mailpit + fake driver (see runbook).

---

9. Documents for Claude

Path	Use
This file `docs/reports/claude-handoff-phase4.md`	Primary status handoff
`docs/reports/waapi-project-report.pdf`	Project overview PDF
`docs/reports/waapi-source-code-documentation.pdf`	Source tree / modules PDF
`docs/reports/security-pass.md`	WP-M triage
`docs/runbook.md`	Ops
`docs/design/billing.md`	Billing design
`review-pack-1.md` / `review-pack-2.md` (gitignored)	Full source dumps + Q&A

Regenerate PDFs: `node docs/reports/render-pdfs.mjs` (Chrome/Edge).

---

10. Known gaps / risks

- WP-N / H / I / final PR not done
- Legal pages still **DRAFT**
- Unofficial WhatsApp ban/protocol risk
- Paddle webhook uses re-stringified JSON body (not raw buffer)

```
- ZAP baseline deferred (manual pre-launch)
- No auto-deploy from this repo
- Local Docker was down during some agent test runs; CI is source of truth for green

---

## 11. Suggested next prompt for Claude / agent

> Continue Phase 4 on branch `phase-4`. Start WP-N (tests first): disconnect alerts, send limits,
PHONE_IN_USE UX, billing sweeper. Then optional WP-H/I. Then update docs/reports, full CI, open ONE PR
phase-4→main and stop. Never merge to main early, never --admin, never print secrets. Read
`docs/reports/claude-handoff-phase4.md` and review packs first.
```